

THE FORENSICS WAY

ISSUE 25

FORENSICS AWARENESS THIS WEEK

TUESDAY, JULY 21, 2026

FRONT PAGE

SUPPLY CHAIN

Poisoning the Well the Machines Drink From: "FakeGit" Floods GitHub With 7,600 Trojanized Repos — and the AI Agents Find Them First

Island's research team, led by Oleg Zaytsev, exposed FakeGit this week — a sprawling operation of roughly 7,600 malicious GitHub repositories published by some 6,600 fake developer profiles, around 800 of them masquerading as AI Skills or MCP servers for platforms like Gmail, Databricks, Jenkins, and Docker. A victim who follows a repo's README downloads a ZIP holding a LuaJIT loader; an obfuscated Lua script then plants the SmartLoader malware, which pulls down the StealC information stealer as its second stage. Campaign repos have logged more than 14 million downloads, and 600-plus malicious listings have surfaced across public MCP registries.

The twist that makes this a forensic milestone is what Island calls "AgentBaiting": autonomous AI coding agents — confirmed across Claude Code, Google Gemini, and OpenAI ChatGPT — discover and pull these poisoned repositories on their own, with no human ever clicking a link. The trust chain that developers extend to open-source code now extends to agents acting at machine speed, turning a search result into code execution. Forensic priority: reconstruct which repositories and MCP packages an agent fetched and ran, hunt the LuaJIT/SmartLoader loader chain and StealC artifacts, and preserve agent session and tool-invocation logs as the new record of how the intrusion began.

GOVERNMENT BREACH

Inside the Circle of Trust: DHS Confirms Hackers Breached HSIN, the Network Where Agencies Share Their Secrets

The Department of Homeland Security confirmed that an unknown actor breached the Homeland Security Information Network (HSIN) — the sensitive-but-unclassified platform federal, state, local, tribal, and private-sector partners rely on to coordinate emergency response and share threat intelligence. The

Threat Bulletin

ACTIVE EXPLOIT

CVE-2026-58644

Microsoft SharePoint Server — a critical remote code execution flaw from deserialization of untrusted data lets an attacker run arbitrary code on-premises; CVSS 9.8. Microsoft published the advisory on July 14 and confirmed active exploitation; CISA added it to the KEV on July 16. Post-exploitation includes theft of IIS machine keys for persistence — the same collaboration platform implicated in this issue's HSIN breach. *Forensic Note:* Review SharePoint ULS and IIS logs for deserialization requests, rotate IIS machine keys, and hunt web shells and malware dropped for persistence.

CRITICAL

CVE-2026-46817

Oracle E-Business Suite — an improper-privilege-management flaw in the File Transmission component of Oracle Payments lets an unauthenticated attacker send a crafted request to /OA_HTML/ibytransmit and fully compromise Payments; CVSS 9.8. First exploited in the wild on June 27, weeks before any public PoC; CISA added it to the KEV on July 15 with a July 18 deadline. *Forensic Note:* Audit web-server logs for requests to the ibytransmit endpoint, hunt unauthorized Payments transactions, and confirm the May 2026 Critical Patch Update is applied.

MALWARE SPOTLIGHT

intrusion, which also reached a SharePoint system used for inter-agency collaboration, is believed to have begun between late May and early June and went undetected for roughly five to six weeks before DHS's Office of Intelligence and Analysis identified it, isolated the affected systems, and opened a forensic investigation.

DHS says there is no indication classified networks were touched and the platform remains operational, but whether documents were exfiltrated from HSIN or its SharePoint back-end is still an open forensic question, and no actor has been named. A breach of the very network built to share sensitive information is trust weaponized at the institutional scale. Forensic priority: reconstruct the intrusion timeline from the late-May entry point, examine SharePoint ULS and IIS logs for the exploitation and any staged data, scope exactly which shared repositories were reachable, and complete the damage assessment before attribution.

ChocoPoC — The Exploit You Cloned Is the Attack

Disclosed by YesWeHack and Sekoia, ChocoPoC is a Python RAT that hides inside fake proof-of-concept exploit repositories on GitHub, each built around a real, high-profile flaw in products like FortiWeb, Ivanti Sentry, Check Point VPN, and PAN-OS. The malice sits in the dependencies — packages named *frint* and *skytext* in requirements.txt — so a routine *pip install* loads a compiled native extension that lifts saved passwords, browser cookies, and files, then hands the attacker a shell, using Mapbox as a dead-drop for command-and-control. *Forensic Note:* Review requirements.txt and installed packages for the malicious dependencies, inspect pip and virtualenv history, and hunt outbound Mapbox API traffic used for C2.

THE FORENSICS WAY

CASE STUDIES: HISTORICAL GRID

THE CCLEANER ATTACK (2017)

A Trusted Update, Turned Trojan: When 2.27 Million Users Downloaded Malware Signed by the Vendor Itself

In September 2017, investigators discovered that attackers had compromised the build environment of Piriform's CCleaner — a wildly popular PC-cleanup utility — and slipped a backdoor into official, digitally signed releases downloaded by roughly 2.27 million users. Forensics revealed a second-stage payload that

THE 3CX CASCADE (2023)

A Supply Chain Inside a Supply Chain: The First Documented Double-Compromise, Traced to a Poisoned Trading App

In March 2023, the 3CX desktop phone app began shipping a trojanized build to its enterprise customers — but the extraordinary finding came when responders traced the root cause backward and discovered 3CX had itself

activated only on a hand-picked list of technology and telecom firms, marking the incident as a targeted espionage play riding a trusted software updater. The investigation, which had to pull apart a legitimately signed binary to find the malice inside, is the direct ancestor of this week's FakeGit operation — the same abuse of trusted distribution, now scaled to thousands of repositories and the AI agents that fetch them.

been breached through a separate poisoned installer, the X_TRADER trading application, attributed to North Korea's Lazarus Group. It was the first publicly documented instance of one software supply-chain attack seeding another, forcing investigators to reason about nested chains of trust. That same cascading abuse — trust borrowed, then borrowed again — is exactly what FakeGit exploits when a poisoned MCP package rides a developer's trust straight into an AI agent's execution.

THE ADOBE BREACH (2013)

153 Million Passwords and the Source Code Too: The Breach That Leaked Both a Company's Users and Its Software

In late 2013, Adobe disclosed a breach that ultimately exposed around 153 million user records — email addresses, poorly encrypted passwords, and unencrypted password hints — alongside the theft of source code for flagship products including ColdFusion and Acrobat. Investigators faced a double forensic problem: the credential dump seeded years of password-reuse attacks once cryptographers cracked the weak ECB-encrypted passwords, while the stolen source code handed adversaries a map to hunt for future zero-days. It is a reminder that trust in a vendor's own code can be turned against everyone downstream — the theme this week's HSIN and FakeGit investigations carry from stolen source into poisoned repositories.

THE ANTHEM BREACH (2015)

One Stolen Login, 78.8 Million Records: How a Single Credential Opened a Health Insurer's Data Warehouse

Disclosed in February 2015, the Anthem breach exposed the personal data of 78.8 million people after a spear-phishing email harvested a single administrator's credentials, which attackers used to burrow into the insurer's data warehouse and exfiltrate records over weeks. The investigation — attributed to a China-linked espionage group — became a landmark study in how one trusted, privileged login becomes the keys to an entire kingdom, and in reconstructing slow exfiltration from data-warehouse logs. Its weeks-long undetected dwell time prefigures exactly the five-to-six-week gap DHS is now reconstructing inside the trusted HSIN network on Page 1.

TOOLS OF THE TRADE

OPEN SOURCE

Syft

ANCHORE — V1.X

Generates a detailed software bill of materials (SBOM) from container images and filesystems, cataloging every package and dependency present. Point it at a project after a FakeGit or ChocoPoC

OPEN SOURCE

packj

OSSILLATE — V0.X

Audits PyPI, npm, and RubyGems packages for signs of malice — install-time hooks, obfuscated code, and suspicious network or filesystem access. Built for exactly this week's threats:

COMMERCIAL

ReversingLabs Spectra Assure

REVERSINGLABS — 2026

Analyzes software packages and build artifacts for tampering, malware, and supply-chain threats without needing source code. Aimed at the FakeGit

UTILITY / SCRIPT

pip-audit

PYPA — V2.X

Official Python utility that scans an environment or requirements file against known-vulnerability databases. Run it across the same developer machines ChocoPoC targets to surface risky

scare to inventory exactly what was pulled in — the first step to spotting a malicious dependency that a quick code review would miss.

flagging the trojanized MCP servers and poisoned PoC dependencies like ChocoPoC's *frint* and *skytext* before *pip install* ever runs them.

problem — deep-inspecting a downloaded package or signed binary to catch the backdoor hidden inside before it reaches a developer's machine or an AI agent's toolchain.

and known-bad dependencies quickly, tightening the loop between a poisoned requirements.txt and a triaged, cleaned build environment.

PRIORITY CVE ADVISORIES

ARCHIVE ALERT

CVE-2026-48282 (ADOBE COLDFUSION)

A path-traversal flaw opening a path to remote code execution in Adobe ColdFusion; CVSS 10.0. Exploited within hours of disclosure with activity traced to India; CISA KEV July 7, July 10 deadline. *Forensic Note:* Review ColdFusion and web-server logs for traversal sequences and anomalous file writes, and hunt newly dropped CFM/JSP web shells.

ARCHIVE ALERT

CVE-2026-55255 (LANGFLOW)

An authorization-bypass (IDOR) flaw letting one tenant reach another's flows in Langflow; CVSS 6.1. Weaponized June 22–25 to steal LLM and AWS credentials from shared instances; CISA KEV July 7. *Forensic Note:* Audit Langflow access logs for cross-tenant flow requests and rotate every LLM and cloud key stored in a flow.

RECENT MALWARE WATCH

ARCHIVE: JULY 14, 2026

MODBEACON — SILVER FOX'S RUST RAT

Attributed by QiAnXin to Silver Fox, a memory-resident, modular Rust RAT that fetches plugins, runs commands, and tunnels command-and-control through gRPC streaming behind Amazon and Cloudflare CDN infrastructure, delivered via SEO poisoning and fake installers. Hunt memory-resident implants with no on-disk payload, inspect outbound gRPC/HTTP2 streams to CDN endpoints, and trace the fake-installer delivery chain.

ARCHIVE: JULY 7, 2026

FRIENDS RANSOMWARE — .FRIENDS124 DOUBLE EXTORTION

Profiled by CYFIRMA, Friends Ransomware encrypts data with strong cryptography and appends the .friends124 extension, then pressures victims by claiming data was exfiltrated before encryption — a steal-then-encrypt model that keeps the leak-site threat alive even against clean backups. Identify encryption onset from .friends124 timestamps, hunt the staging that precedes encryption, and preserve ransom notes.